Protocolo SSH

SSH

SSH™ (o Secure SHell) es un protocolo que facilita las comunicaciones seguras entre dos sistemas usando una arquitectura cliente/servidor y que permite a los usuarios conectarse a un host remotamente.

SSH encripta la sesión de conexión, haciendo imposible que alguien pueda obtener ninguna parte de la información transmitida.

SSH está diseñado para reemplazar los métodos más viejos y menos seguros para registrarse remotamente en otro sistema a través de la shell de comando, tales como telnet o rsh.

Un programa relacionado, el scp, reemplaza otros programas diseñados para copiar archivos entre hosts como rcp.

Criptografía

La criptografía es la rama de las matemáticas que estudia el cifrado de información legible e información que no puede ser leída directamente, al tener que ser descifrada.

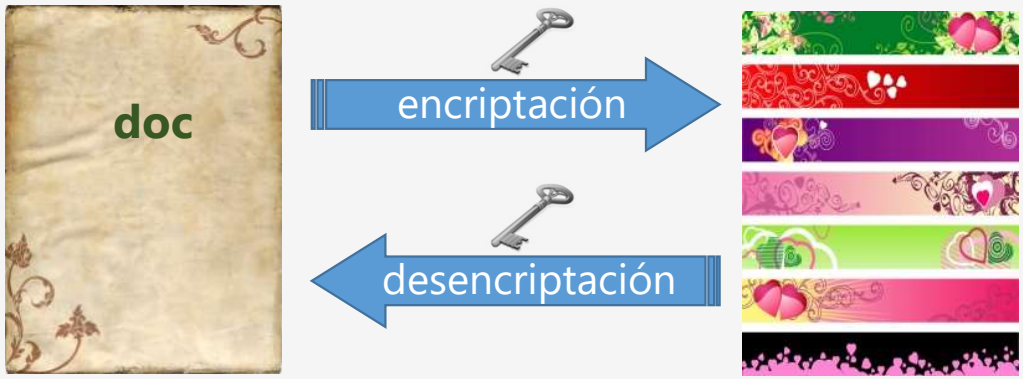
Los sistemas de criptografía informáticos utilizan un algoritmo asociado a una clave o **llave** para convertir un mensaje inicial en un mensaje codificado que no puede ser decodificado más que mediante un algoritmo de decodificación asociado a una **llave de desencriptación**

Existen dos esquemas clásicos de encriptación:

- La encriptación simétrica
- La asimétrica o criptografía de claves públicas

Criptografía Simétrica

Obliga a al emisor y receptor a utilizar **la misma clave** para encriptar y desencriptar el mismo documento



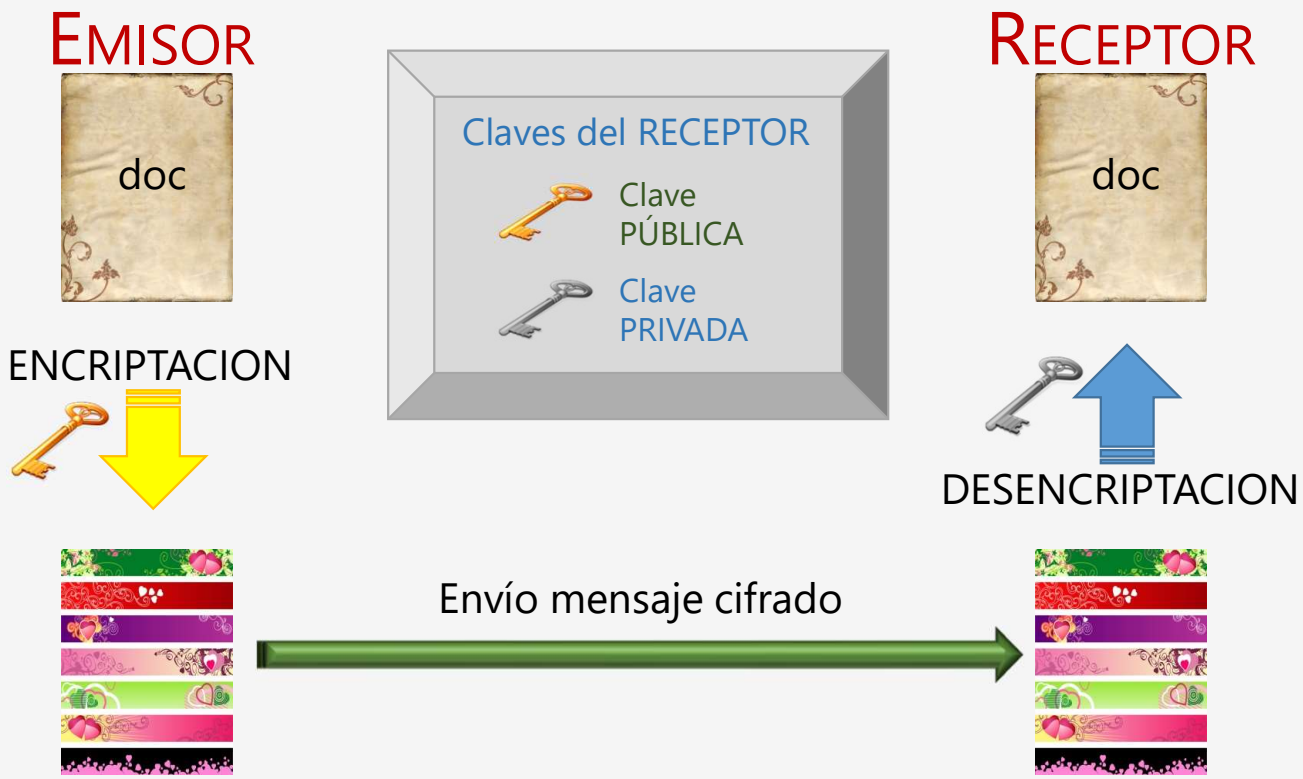
Ejemplo: el criptosistema DES, *Data Encription Standard*, desarrollado por IBM.

Criptografía Asimétrica

Usa el concepto de **pares de claves**, de forma que cada uno de los elementos del par (una clave) puede encriptar información que solo la otra componente del par (la otra clave) puede desencriptar

El par de claves se asocia con un solo interlocutor, así un componente del par (la **clave privada**) solamente es conocida por su propietario mientras que la otra parte del par (la **clave pública**) se publica ampliamente para que todo el mundo pueda verla

Transmisión segura



Transmisión segura

La transmisión segura se realiza encriptando el mensaje o documento a enviar con la clave pública del receptor.

En el esquema anterior se asegura la confidencialidad. Nadie que intercepte el mensaje puede leerlo ya que no dispone de la clave privada del receptor para desencriptarlo.

El receptor recupera el mensaje haciendo uso de su clave privada.

Firma electrónica

- ¿Qué ocurre si invertimos el uso de las llaves?

Si se invierte el uso de las llaves obtendremos un mensaje que ha sido cifrado por una persona haciendo uso de su propia clave privada y que puede ser descifrado por cualquier otra, simplemente consiguiendo y haciendo uso de su clave pública. Se obtiene así un efecto de personalización del documento, semejante a una firma.

Este es el fundamento de la firma electrónica

Firma electrónica

En vez de encriptar el documento completo, al realizar una firma electrónica, el sistema ejecuta un algoritmo sobre el documento obteniendo un extracto o huella de longitud fija determinada (aprox. 160 bytes).

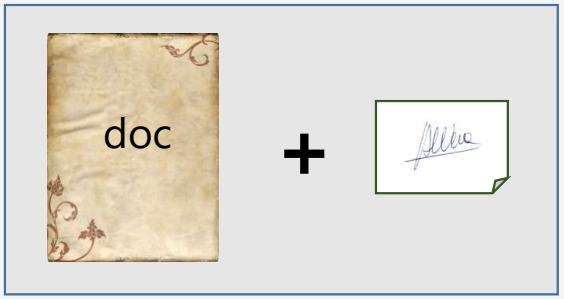
Esta huella es única. Ante cualquier modificación del documento, se generaría un extracto totalmente diferente y por ello, no se correspondería con el original.

El extracto conseguido, se somete seguidamente a un cifrado mediante la clave secreta del titular.

Firma electrónica

Firma electrónica

El algoritmo más utilizado en este procedimiento de encriptación asimétrica es el RSA. Con él se obtiene un extracto final cifrado con la clave privada del autor, que se añadirá al final del texto o mensaje para que se pueda verificar la **autoría** e **integridad** del documento fácilmente por quien disponga de la clave pública del mismo.



Firma electrónica

Determinación de la validez del documento:

- Con la clave pública del remitente (obtenida a través de una Autoridad de Certificación), se descifrará el extracto cifrado del autor.
- Se calculará el extracto que le correspondería al texto del mensaje.
- Si el resultado coincide con el extracto anteriormente descifrado, se considera un documento válido.
- en caso contrario significaría que el documento ha sufrido una modificación posterior y por tanto no es válido.

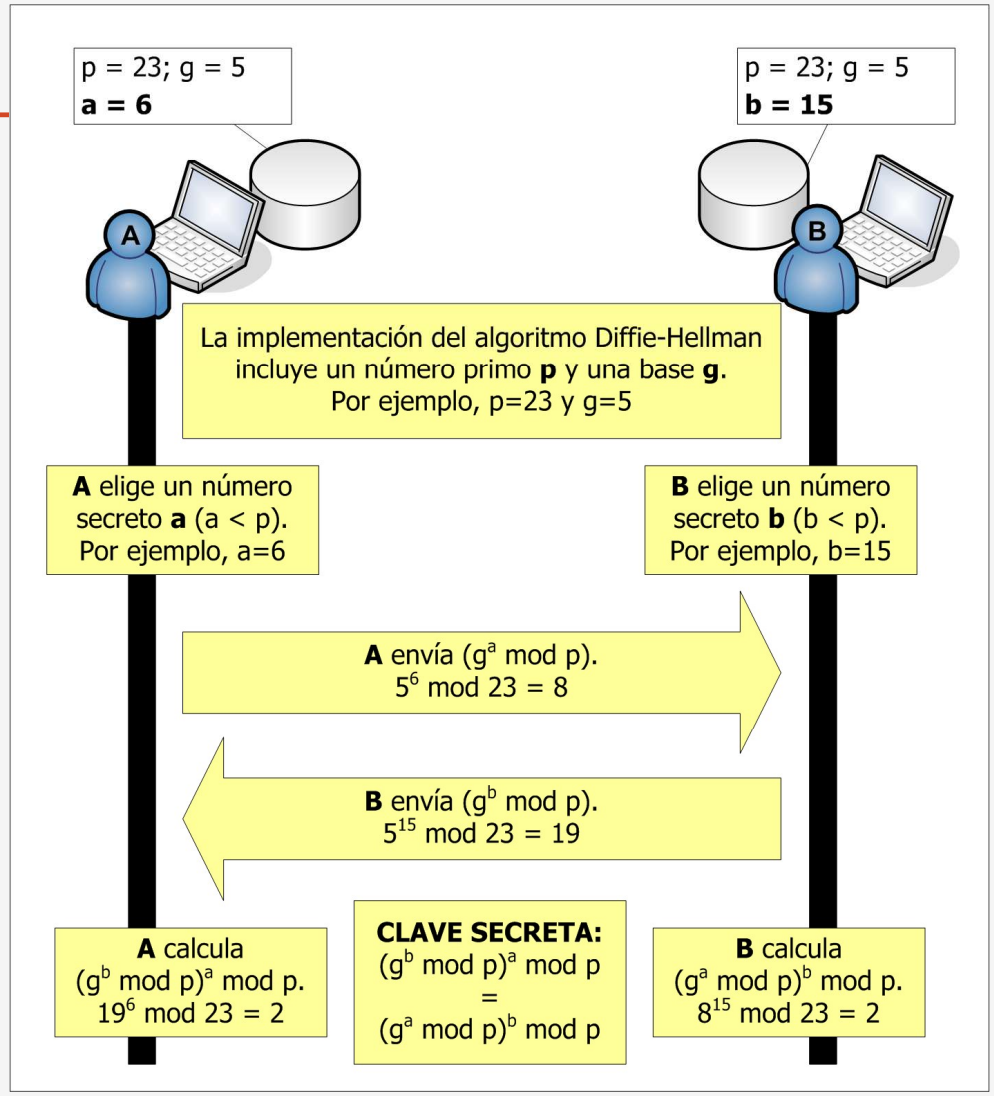
Protocolo de Diffie y Hellman para intercambio de claves

En una comunicación entre dos partes es de mucha utilidad generar una clave secreta común para cifrado.

Whitfield Diffie y Martin Hellman utilizaron ideas de la teoría de números para construir un protocolo de intercambio de claves, el cual dio comienzo a la era de los criptosistemas de clave pública. Fue publicado en 1976.

Las implementaciones actuales del protocolo Diffie-Hellman utilizan números primos muy grandes, lo que impide a un atacante calcular los valores de “a” y “b”. El valor “g” no necesita ser grande, y en la práctica su valor es 2 ó 5. En el RFC 3526 aparecen publicados los números primos que deben utilizarse. A modo de ejemplo, se facilita aquí el número primo de 1024 bytes propuesto. El valor “g” utilizado es 2:

$$p = 2^{8192} - 2^{8128} - 1 + 2^{64} \times ((2^{8062}\ pi) + 4743158)$$



SSH

Cuando un cliente de SSH se conecta al servidor, se realizan los siguientes pasos:

1. El cliente abre una conexión TCP al puerto 22 del host servidor.
2. El cliente y el servidor acuerdan la versión del protocolo a utilizar, de acuerdo a su configuración y capacidades.
3. El servidor posee un par de claves pública/privada de RSA (llamadas “claves de host”). El servidor envía al cliente su clave pública.
4. El cliente compara la clave pública de host recibida con la que tiene almacenada, para verificar su autenticidad. Si no la conociera previamente, pide confirmación al usuario para aceptarla como válida.

SSH

5. El cliente genera una clave de sesión aleatoria y selecciona un algoritmo de cifrado simétrico.
6. El cliente envía un mensaje conteniendo la clave de sesión y el algoritmo seleccionado, cifrado con la clave pública de host del servidor usando el algoritmo RSA.
7. En adelante, para el resto de la comunicación se utilizará el algoritmo de cifrado simétrico seleccionado y clave compartida de sesión.
8. Luego se realiza la autenticación del usuario. Aquí pueden usarse distintos mecanismos. Ahora analizaremos los más importantes.
9. Finalmente se inicia la sesión, por lo general, interactiva.

Formas de autentificación con SSH

- **Con password:** Una vez establecido el canal cifrado por SSH, se envían login y password hacia el servidor. El servidor comprueba que el usuario existe, y que la contraseña es correcta comparándola con la entrada correspondiente del fichero de /etc/passwd o /etc/shadow.
- El usuario debe escribir su contraseña cada vez que se conecta al servidor.
- **Con clave pública:** Para poder llevarse a cabo, el usuario debe tener un par de claves pública/privada, y la clave pública debe estar almacenada en el servidor. Luego de establecida la conexión, el servidor genera un número aleatorio llamado "desafío" (challenge) que es cifrado con la clave pública del usuario usando RSA o DSA. El texto cifrado es enviado al cliente, que debe descifrarlo con la clave privada correspondiente y devolverlo al servidor, demostrando de esta manera que el usuario es quien dice ser.
- Las ventajas que aporta este método son evitar que el usuario tenga que recordar y escribir contraseñas, y evitar que la contraseña del usuario viaje hacia el servidor, ni tan siquiera encriptada.

Seguridad SSH

Una de las principales fortalezas de SSH es la seguridad: ni bien se establece la conexión, y antes de la autenticación del usuario, queda establecido un canal cifrado seguro. En adelante, todo el tráfico de la sesión será indescifrable.

Importante: No debe confundirse el hecho de que el cliente y el servidor utilicen RSA para establecer la comunicación cifrada, con el hecho de que un usuario pueda utilizar el mismo algoritmo para autenticarse ante el servidor. Son dos etapas bien diferenciadas e independientes (aunque puede utilizarse el mismo algoritmo de cifrado en ambas).

OpenSSH

OpenSSH ya está instalado de manera predeterminada, incluso con la instalación Mínima, por lo que no se necesitan instalar nuevos paquetes. Puede iniciar sesión con la autenticación de contraseña de forma predeterminada.

Sin embargo, de forma predeterminada, la cuenta de usuario root puede iniciar sesión, por lo que es mejor cambiar la configuración.

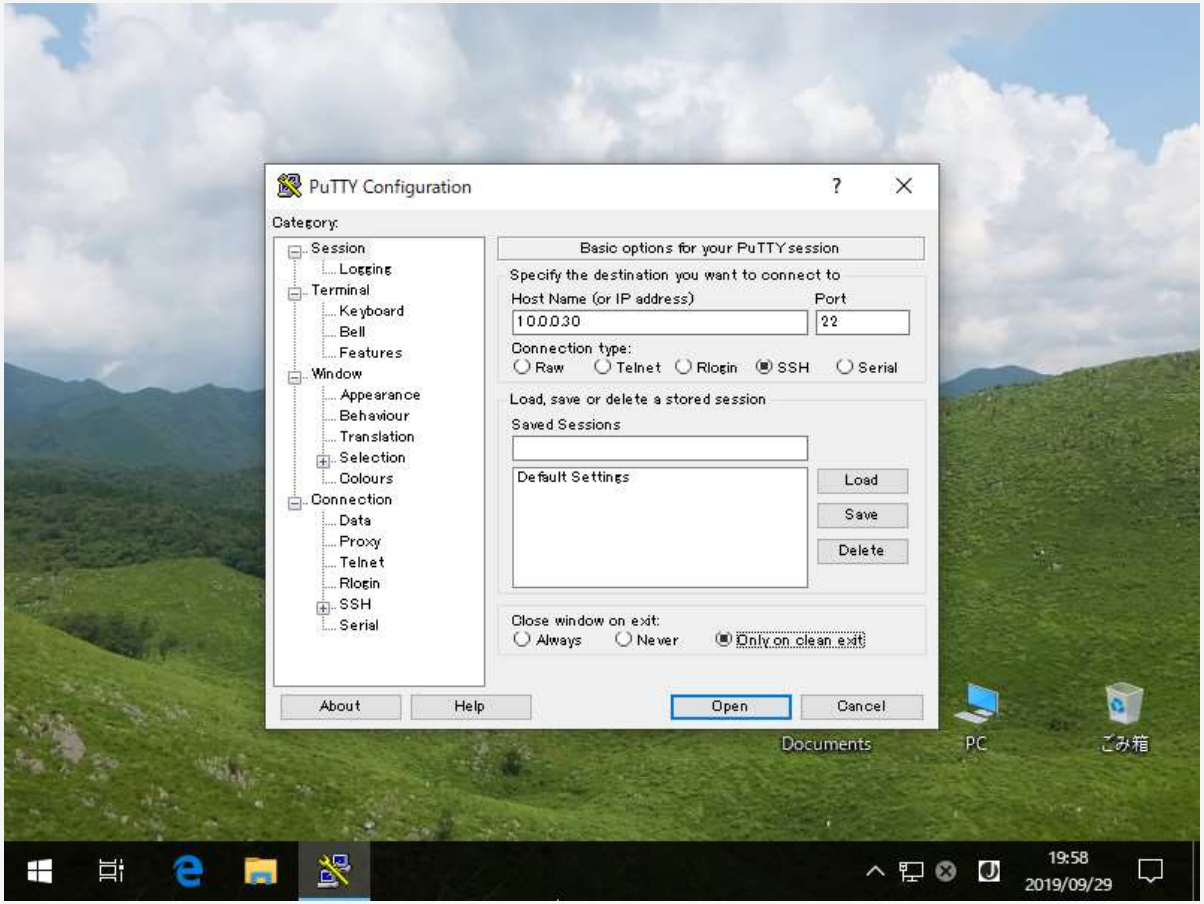
```
# vi /etc/ssh/sshd_config

PermitRootLogin no

# systemctl restart sshd
```

Estableciendo conexión ssh-client

ssh [username@(hostname or IP address)]

[root@client ~]# **ssh usuario@server.as.local**
The authenticity of host ‘server.as.local(192.168.56.30)' can't be established.
ECDSA key fingerprint is SHA256:8Z/t+IUd/X5K991abSyV6zML+6GeoGmfTUibuTOt++w.
Are you sure you want to continue connecting (yes/no)? **yes**
Warning: Permanently added ‘server.as.local,192.168.56.30' (ECDSA) to the list of known hosts.
usuario@server.as.local's password: **xxxxxxxxxx**
Activate the web console with: systemctl enable --now cockpit.socket

Estableciendo conexión - putty



Estableciendo conexión - PowerShell

cent@dlp:~

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\hiroyuki> ssh -V
OpenSSH_for_Windows_7.7p1, LibreSSL 2.6.5
PS C:\Users\hiroyuki>
PS C:\Users\hiroyuki> ssh cent@10.0.0.30
The authenticity of host '10.0.0.30 (10.0.0.30)' can't be established.
ECDSA key fingerprint is SHA256:8Z/t+IUd/X5K991abSyV6zML+6GeoGmfTUibuTOt++w.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '10.0.0.30' (ECDSA) to the list of known hosts.
cent@10.0.0.30's password:
Activate the web console with: systemctl enable --now cockpit.socket

Last login: Wed Oct  2 10:28:42 2019
[cent@dlp ~]$
[cent@dlp ~]$ cat /etc/os-release
NAME="CentOS Linux"
VERSION="8 (Core)"
ID="centos"
ID_LIKE="rhel fedora"
VERSION_ID="8"
PLATFORM_ID="platform:el8"
PRETTY_NAME="CentOS Linux 8 (Core)"
ANSI_COLOR="0;31"
CPE_NAME="cpe:/o:centos:centos:8"
HOME_URL="https://www.centos.org/"
BUG_REPORT_URL="https://bugs.centos.org/"

CENTOS_MANTISBT_PROJECT="CentOS-8"
CENTOS_MANTISBT_PROJECT_VERSION="8"
REDHAT_SUPPORT_PRODUCT="centos"
REDHAT_SUPPORT_PRODUCT_VERSION="8"

[cent@dlp ~]$
```

11:39 AM
10/2/2019

Comandos básicos ssh

- **ssh**

El comando ssh ofrece comunicación encriptada y segura entre dos sistemas sobre una red no segura. Este comando reemplaza al telnet, rlogin, rsh.

- **scp**

El comando scp permite copiar ficheros entre dos máquinas. Utiliza ssh para la transmisión de la información, por lo que ofrece la misma seguridad que el ssh. De la misma manera utiliza los métodos de autenticación de ssh. Este comando reemplaza al rcp, ftp.

- **sftp**

El comando sftp transfiere archivos entre máquinas de forma interactiva.

Es posible ejecutar comandos en el servidor remoto con ssh

 # ssh usuario@server.as.local "cat /etc/passwd"

Iniciando sesión remota con clave pública

1. Generar las claves (en el servidor)

```
# ssh-keygen
```

Generating public/private rsa key pair.
Enter file in which to save the key (/home/asuser/.ssh/id_rsa):
Enter passphrase (empty for no passphrase): frase_secreta
Enter same passphrase again: frase_secreta

```
 # ll ~/.ssh
-rw-------. 1 asuser asuser 1876 Sep 29 20:34 id_rsa
-rw-r--r--. 1 asuser asuser  400 Sep 29 20:34 id_rsa.pub

# mv ~/.ssh/id_rsa.pub ~/.ssh/authorized_keys
```

Iniciando sesión remota con clave pública

2. Transferir la clave privada al cliente

(ejecutar en el cliente)

```
# mkdir ~/.ssh
# chmod 700 ~/.ssh

// Transferimos la clave privada
# scp asuser@server.as.local:/home/asuser/.ssh/id_rsa ~/.ssh/
asuser@server.as.local's password:
id_rsa                                    100% 1876   193.2KB/s   00:00
```

Al administrador puede configurar entonces /etc/ssh/sshd_config

PasswordAuthentication no

Iniciando sesión remota con clave pública

3. Iniciando sesión

```
# ssh asuser@server.as.local
Enter passphrase for key '/home/asuser/.ssh/id_rsa': frase_secreta
Activate the web console with: systemctl enable --now cockpit.socket

Last login: Sun Sep 29 20:33:58 2019
[asuser@server ~]$
```

4. Podemos usar ssh-agent para automatizar la introducción de la frase secreta

```
# ssh-add
Enter passphrase for /home/asuser/.ssh/id_rsa: frase_secreta
Identity added: /home/asuser/.ssh/id_rsa (asuser@server.as.local)
```

Tunel SSH

Ahora, una de las formas como podemos sacar el máximo provecho a SSH es creando un túnel SSH el cual nos permite navegar con niveles más altos de seguridad y evitando reglas o políticas que impidan el acceso a determinados sitios.

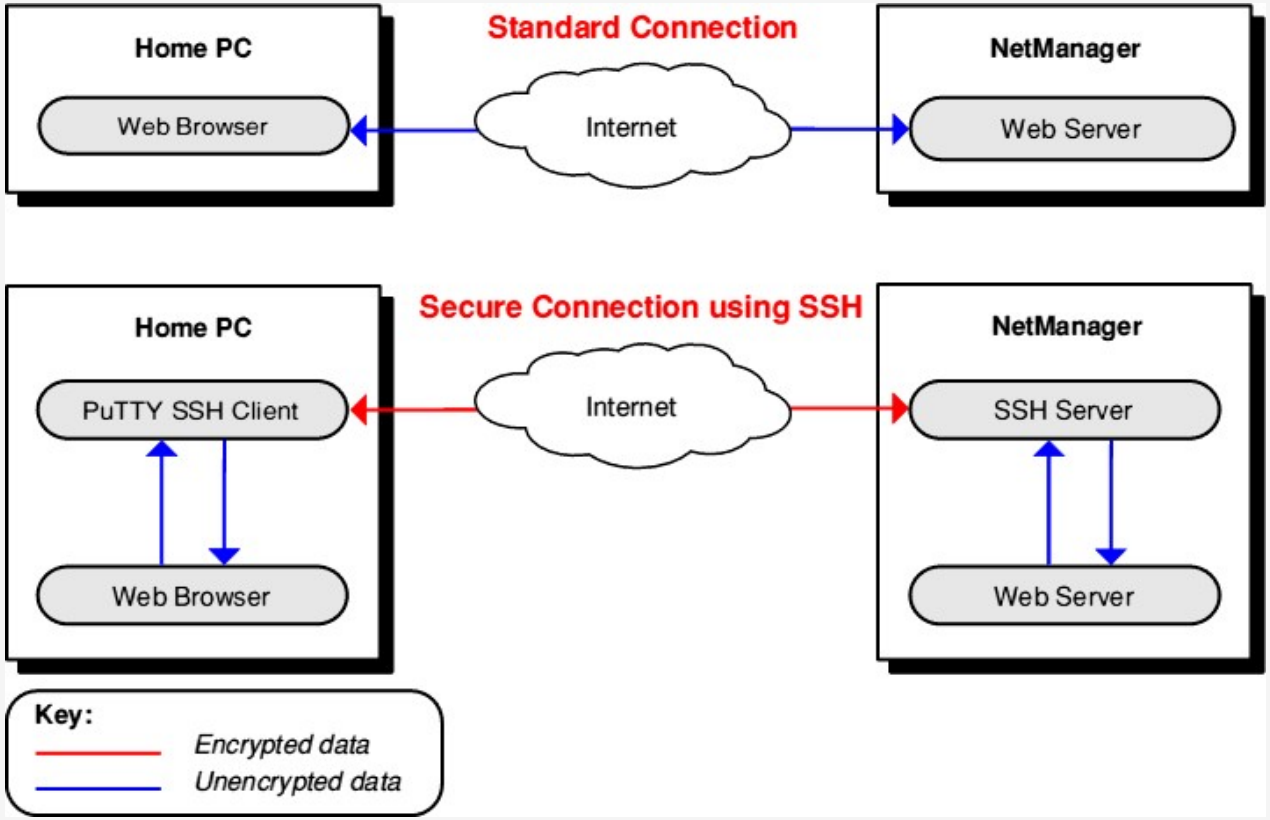
Un túnel SSH nos brinda las siguientes características:

- Evitar ataques ARP o ARP Spoofing.
- Prevenir ataques tipo Man in the Middle (MitM).
- Evitar que todo el tráfico de red que estamos usando sea analizado y capturado.

El funcionamiento del túnel SSH consiste básicamente en crear un “túnel” que parte desde el servidor de origen hasta el equipo cliente gestionando de forma adecuada todo el tráfico que pasa por él. En la siguiente imagen podemos ver un esquema de este funcionamiento.

Tunel SSH

Al establecer la comunicación, la petición http viajara por el túnel SSH que ha sido configurado previamente y tanto la petición como el tráfico entrante y saliente estará cifrado protegiendo protocolos vulnerables como HTTP, SMTP. FTP, Telnet y demás.



Tunel SSH

```
# ssh -f usuario@servidor -L 2000:servidor:25 –N
```

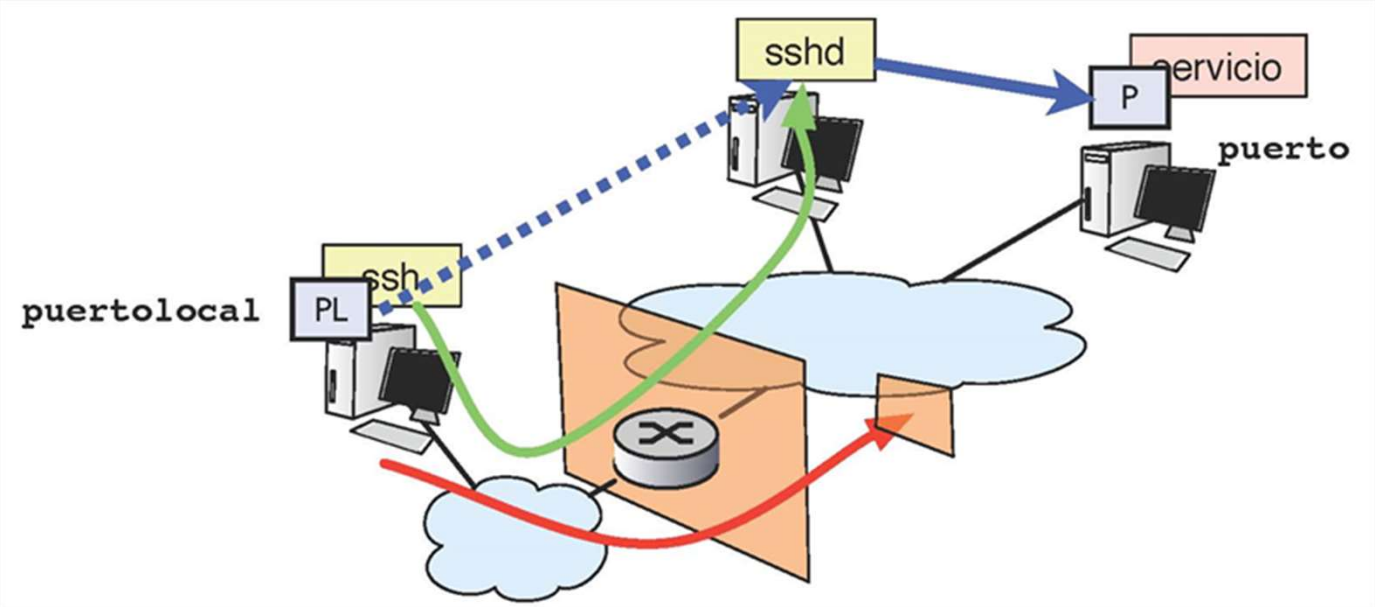
- -f: ir a background
- -L 2000:ordenador-personal:25 es de la forma puertolocal:host:puertoremoto
- -N: no ejecutar un intérprete de comandos en el sistema remoto

- Reenvía el puerto 2000 del ordenador local al puerto 25 del servidor, encriptando la comunicación
- Permite acceder al puerto 25 del servidor si estamos tras un firewall que no bloquee el puerto 22

Ejemplo: Túnel (nivel de transporte) sobre SSH

- **Escenario 1**: ssh permitido pero puerto P filtrado
- **Solución**: Redireccionar un puerto local

```
$ ssh usuario@host -L puertolocal:destino:puerto
```



- Para el destino la conexión viene de H2

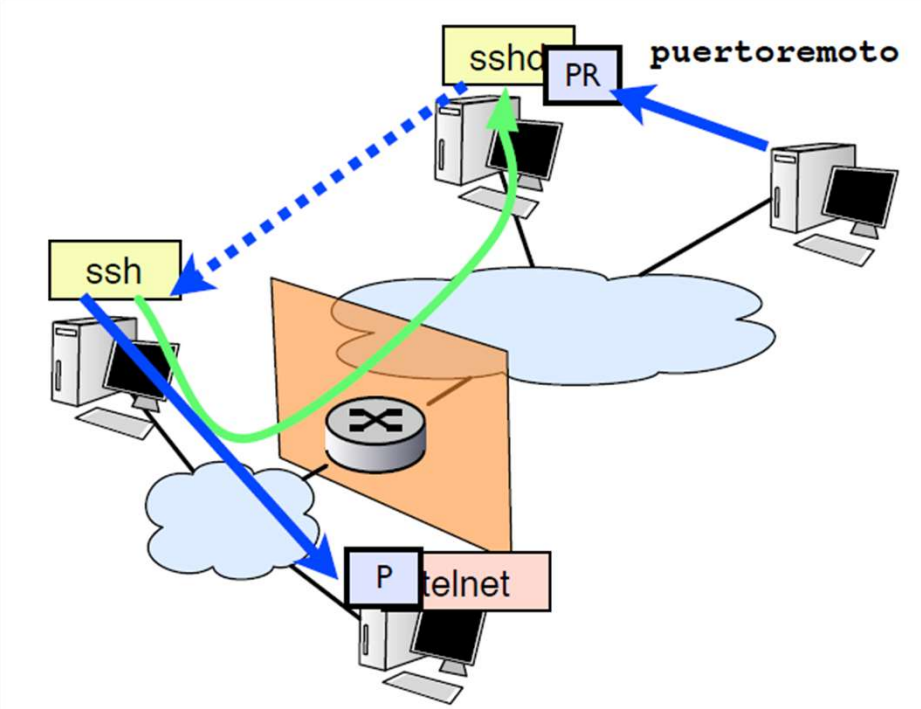
Ejemplo: Túnel (nivel de transporte) sobre SSH

- **Escenario 2**: ssh permitido pero puerto remoto filtrado
- **Solución**: Redireccionar un puerto remoto

```
$ ssh usuario@host -R puertoremoto:destino:puerto
```

- Redirecciona puertos del servidor hacia la red del cliente de ssh

- Puede usarse para proteger servicios clásicos



VPN

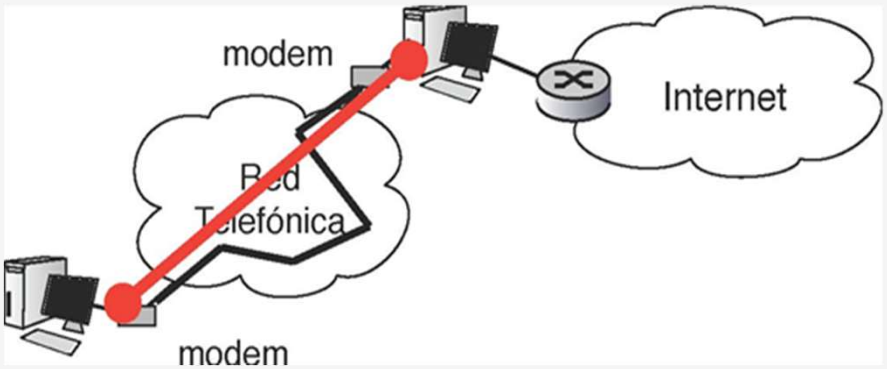
Virtual Private Network

Extensión de la seguridad

- En ocasiones queremos extender la red de una empresa más allá de los limites del edificio.
- Antiguamente se usaban líneas telefónicas alquiladas para unir routers en las sedes remotas y tener un enlace.

ENLACE PUNTO A PUNTO

- Un emisor, un receptor.
- Más fácil que LAN.
- No hay medio compartido que arbitrar
- No hay necesidad de direccionamiento



Extensión de la seguridad

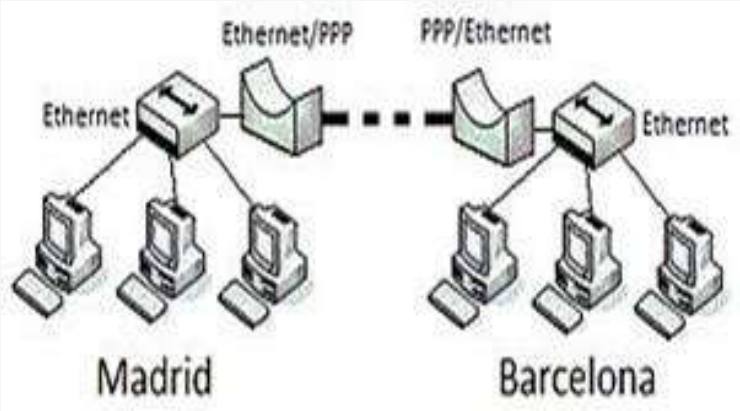
- En ocasiones queremos extender la red de una empresa más allá de los limites del edificio.
- Antiguamente se usaban líneas telefónicas alquiladas para unir routers en las sedes remotas y tener un enlace.

ENLACE PUNTO A PUNTO

Los protocolos de nivel de enlace punto apunto más populares:

> PPP (point to point protocol)

> HDLC (high-level data link control)



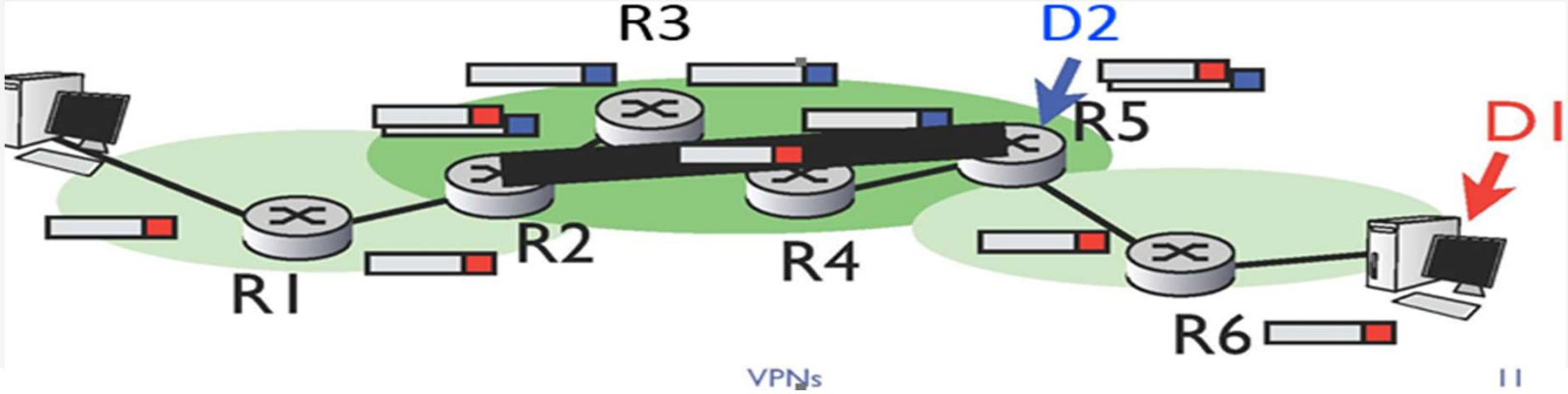
Extensión de la seguridad

Tenemos la posibilidad de enviar esos paquetes a través de Internet:

- **Cobertura** en cualquier parte (no hace falta tener preparada la línea alquilada)
- **Ahorro** (no hace falta pagar la línea alquilada)
- **Seguridad** (podemos cifrar las comunicaciones y olvidarnos de si pinchan o no el cable)

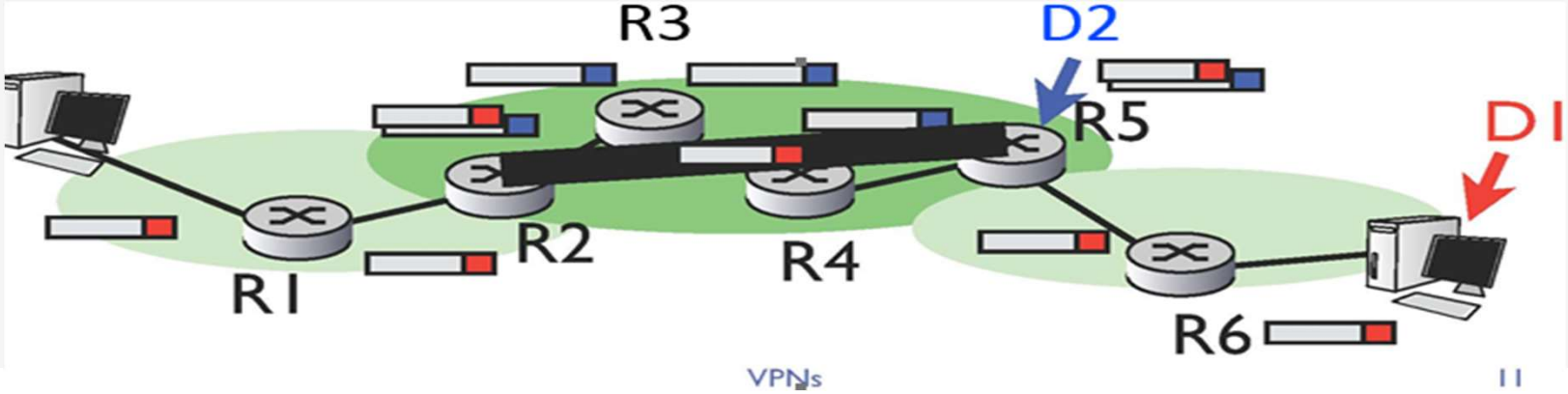
Túneles

- Al transportar un paquete en una red de ordenadores este es encaminado siguiendo la dirección de destino del paquete (D1)
- Si un router intermedio R2 encapsula el paquete que va a D1 dentro de un nuevo paquete que va a R5 (D2) los routers R3 y R4 encaminarán ese paquete a hacia R5 sin saber el destino final del paquete. Se dice que el paquete ha sido enviado a través de un túnel R2-R5



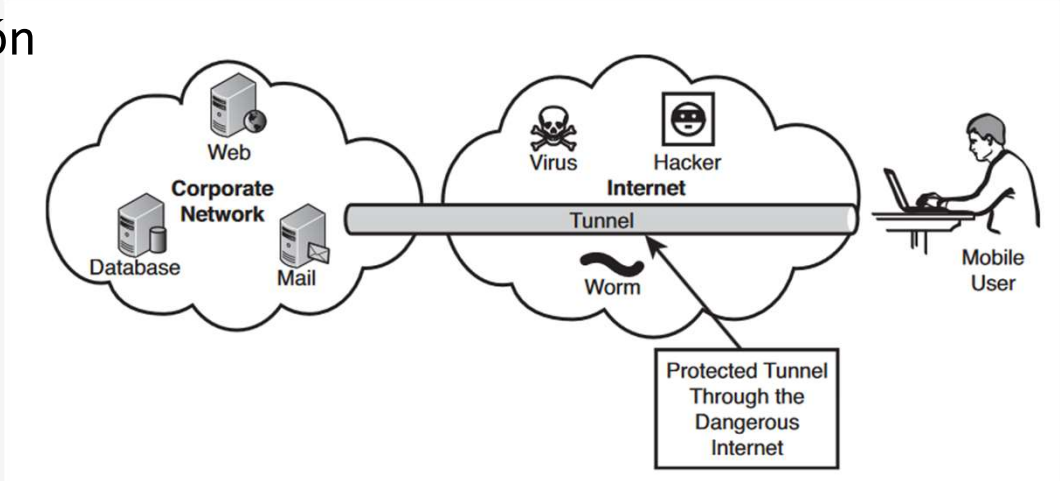
Túneles

- Al transportar un paquete en una red de ordenadores este es encaminado siguiendo la dirección de destino del paquete (D1)
- Los routers intermedios actuan como un nivel de enlace punto a punto entre R2 y R5



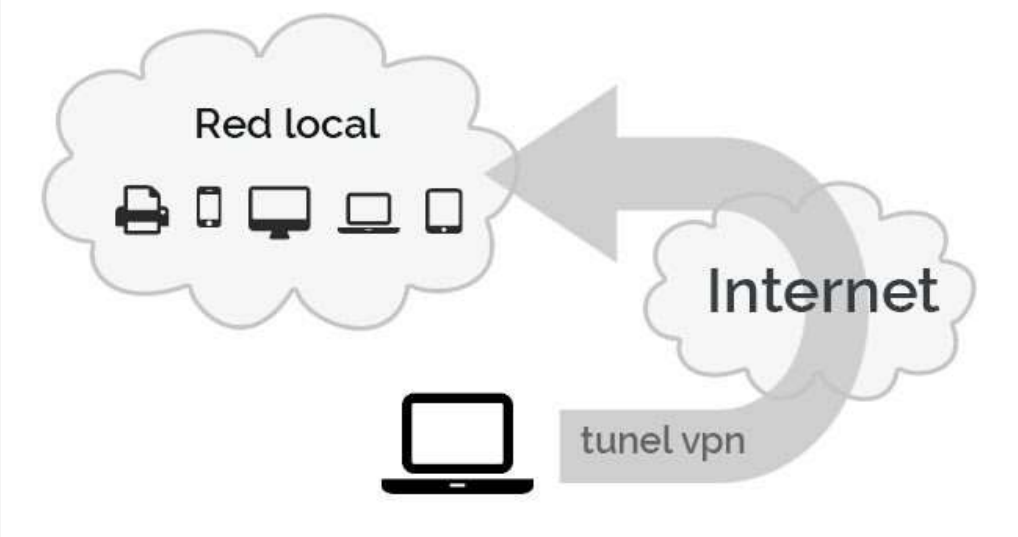
VPN – Virtual Private Network

- Una red privada virtual (VPN), es una tecnología de red de ordenadores que permite una extensión segura de la red de área local (LAN) sobre una red pública o no controlada como Internet.
- Permite acceder a la red privada desde fuera de las infraestructuras de la empresa, con soporte para todo tipo de tráfico (no sólo una conexión ssh interactiva o un tunel ssh para redireccionar un puerto)



VPN – Virtual Private Network

- Permite que el ordenador en la red envíe y reciba datos sobre redes compartidas o públicas como si fuera una red privada con toda la funcionalidad, seguridad y políticas de gestión de una red privada.



VPN – Tecnologías

- **Autenticación y Control de acceso**: las VPN deben verificar la identidad de los usuarios y evitar el acceso de aquellos que no se encuentren autorizados.
- **Seguridad de los datos** (encriptación): los datos que se van a transmitir a través de la red pública (Internet), deben cifrarse, para que no puedan ser leídos si son interceptados. Esta tarea se realiza con algoritmos de cifrado simétrico como DES, 3DES o AES que únicamente pueden ser leídos por el emisor y receptor.
- **Tunneling**

Tipos de VPN

- **VPN de acceso remoto**: consiste en usuarios que se conectan con la empresa desde sitios remotos (oficinas comerciales, domicilios, hoteles, aviones preparados, etcétera) utilizando Internet como vínculo de acceso. Una vez autentificados tienen un nivel de acceso muy similar al que tienen en la red local de la empresa.
- **VPN punto a punto**: Este esquema se utiliza para conectar oficinas remotas con la sede central de la organización. El servidor VPN, que posee un vínculo permanente a Internet, acepta las conexiones vía Internet provenientes de los sitios y establece el túnel VPN.
- **VPN over LAN**: Es una variante del tipo "acceso remoto" pero, en vez de utilizar Internet como medio de conexión, emplea la misma red de área local (LAN) de la empresa. Sirve para aislar zonas y servicios de la red interna.

Implementaciones VPN

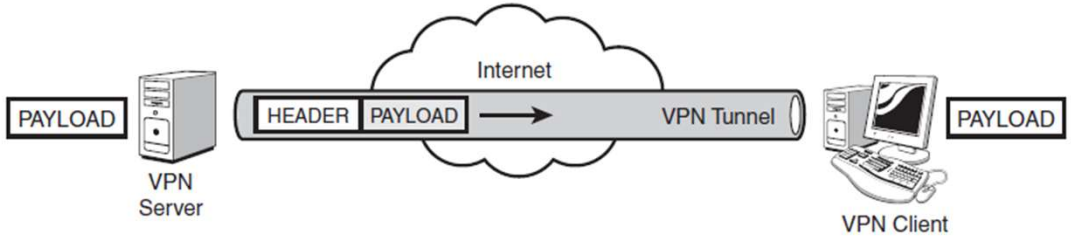
- El protocolo estándar de facto es el **IPSEC**, pero también están PPTP, L2F, L2TP, SSL/TLS, SSH, etc. Cada uno con sus ventajas y desventajas en cuanto a seguridad, facilidad, mantenimiento y tipos de clientes soportados.
- Actualmente hay una línea de productos en crecimiento relacionada con el protocolo **SSL/TLS**, que intenta hacer más amigable la configuración y operación de estas soluciones.
- Las soluciones de hardware casi siempre ofrecen mayor rendimiento y facilidad de configuración, aunque no tienen la flexibilidad de las versiones por software.
- Las aplicaciones VPN por software son las más configurables aunque el rendimiento es menor y la configuración más delicada. Aquí encontramos productos de código abierto como OpenSSH, **OpenVPN** y FreeS/Wan.

Protocolos VPN

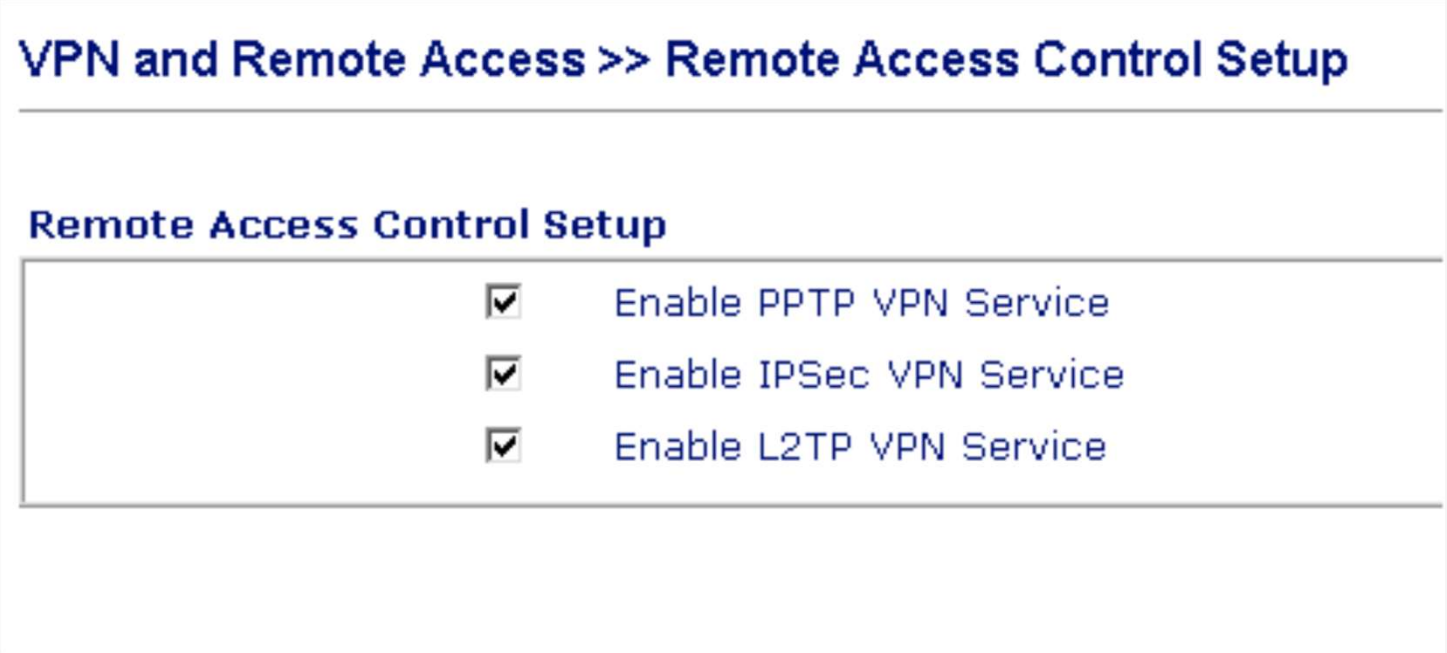
- **IPSec** o Internet Protocol Security: es una extensión del tradicional protocolo IP para redes VPN. Es lo suficientemente seguro para ser usado por empresa para conectar sucursales o a sus usuarios de forma remota. Cifrará cualquier conexión, por lo que asegura privacidad e integridad de los datos
- **L2TP** o Layer 2 Tunneling Protocol: es un protocolo para encapsular los datos que a su vez utilizarán IPSec para encriptarlos y enrutarlos por la red. A este método se le llama línea virtual ya que es de uso sencillo y el encabezado del paquete cuenta con la información suficiente como IP para que el servidor VPN identifique al usuario que lo manda o lo envía.
- **PPTP** o Point-to-Point Tunneling Protocol: es un protocolo para encriptar y encapsular los paquetes con el protocolo IP de una forma simple. Es uno de los protocolos más rápidos, aunque con una protección menos contundente que los anteriores por tener una encriptación más frágil.
- **L2F** o Layer 2 Forwarding: es un protocolo similar al PPTP creado por la empresa Cisco Systems. En este caso usa las redes de acceso telefónico para trasportar los paquetes, y al igual que el anterior, necesita de otro protocolo como IP para cifrar el contenido del paquete.
- **SSL VPN** o Secure Lockets Layer: destaca por su versatilidad y su gran implementación para el acceso web. A priori no necesita la instalación de un cliente VPN, por lo que es de uso muy común en teletrabajo.
- **OpenVPN**: además de ser un software cliente para conectarnos a una VPN, también es un protocolo de red punto a punto. Este protocolo es de código libre y permite establece el túnel entre el cliente servidor utilizando OpenSSL para la encriptación. Además, es capaz de usar los protocolos de transporte TCP o UDP para la transmisión de los datos.
- **IKEv2**: es la evolución del protocolo Internet Key Exchange, es otro protocolo que utiliza IPSec para encriptar los paquetes de datos, aunque de forma más simple para mejorar la velocidad de los mismos. Éste establece la asociación de seguridad entre los puntos de transmisión.

Comparativa estándares PPTP, L2TP/IPSec y SSTP

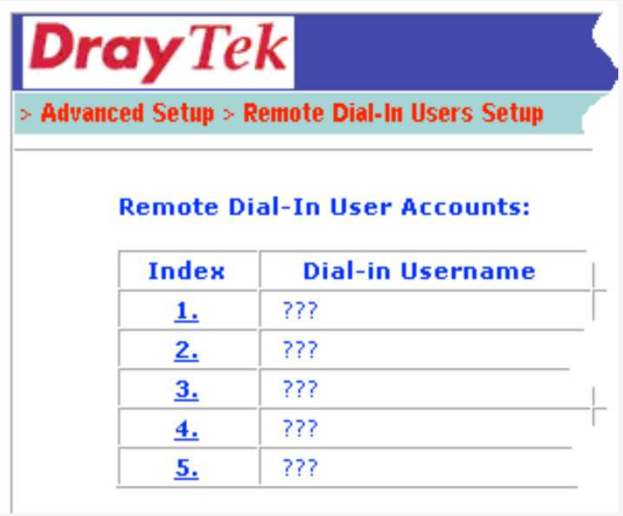
Characteristics	PPTP	L2TP/IPSec	SSTP
Encapsulation	GRE	L2TP over UDP	SSTP over TCP
Encryption	Microsoft Point-to-Point Encryption (MPPE) with RC4	IPSec ESP with Triple Data Encryption Standard (3DES) or Advanced Encryption Standard (AES)	SSL with RC4 or AES
Tunnel maintenance protocol	PPTP	L2TP	SSTP
When user authentication occurs	Before encryption begins	After the IPSec session is established	After the SSL session is established
Certificates needed	None	Computer certificates on both the VPN client and VPN server	Computer certificate on the VPN server and root CA certificate on the VPN client
Client	Windows 9x and above	Windows 2000 and above	Windows Server 2008, Windows XP SP3, and Windows Vista SP1



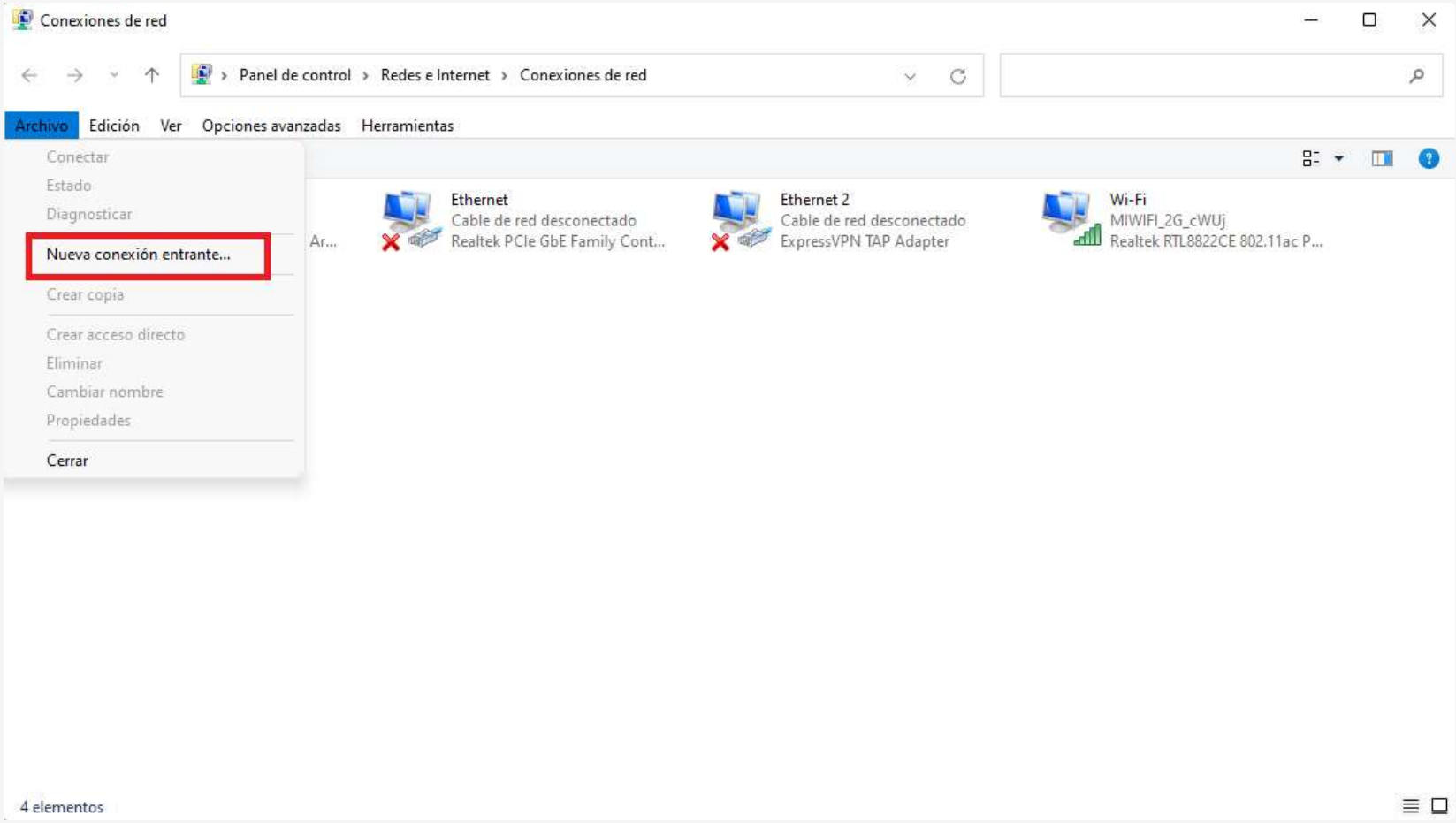
VPN en un router (Draytek Vigor)



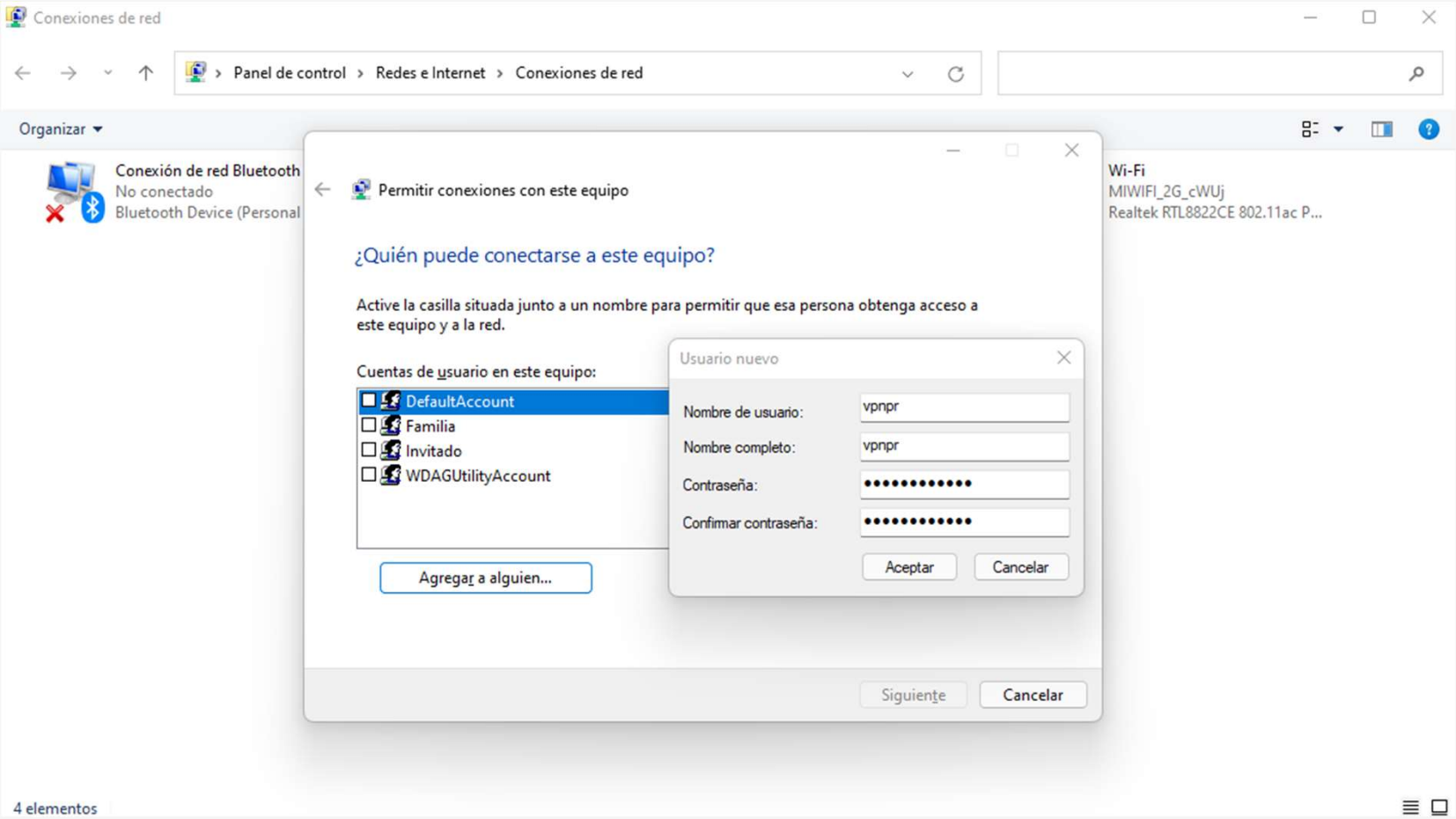
VPN en un router (Draytek Vigor)



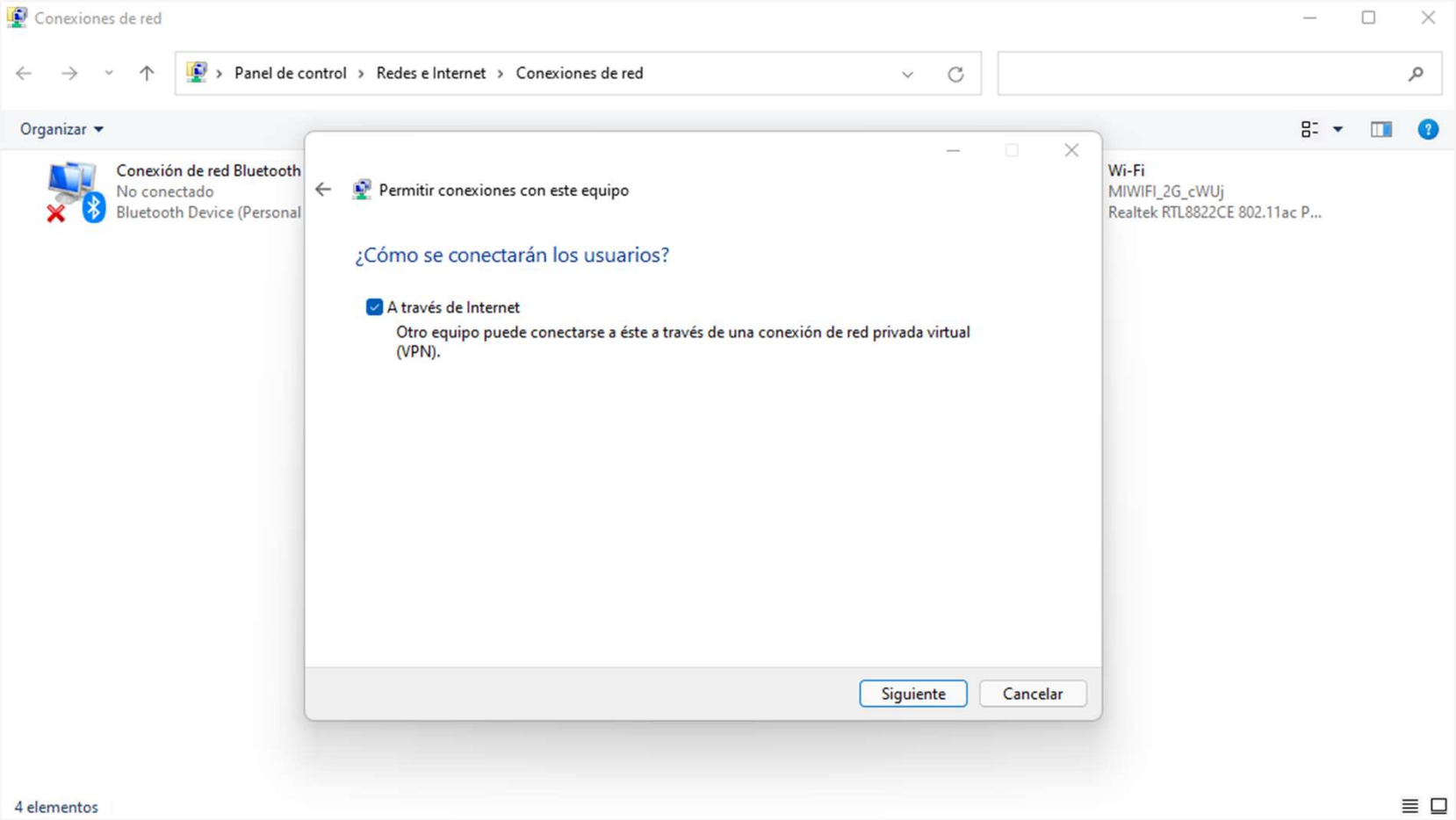
Configuración VPN W10



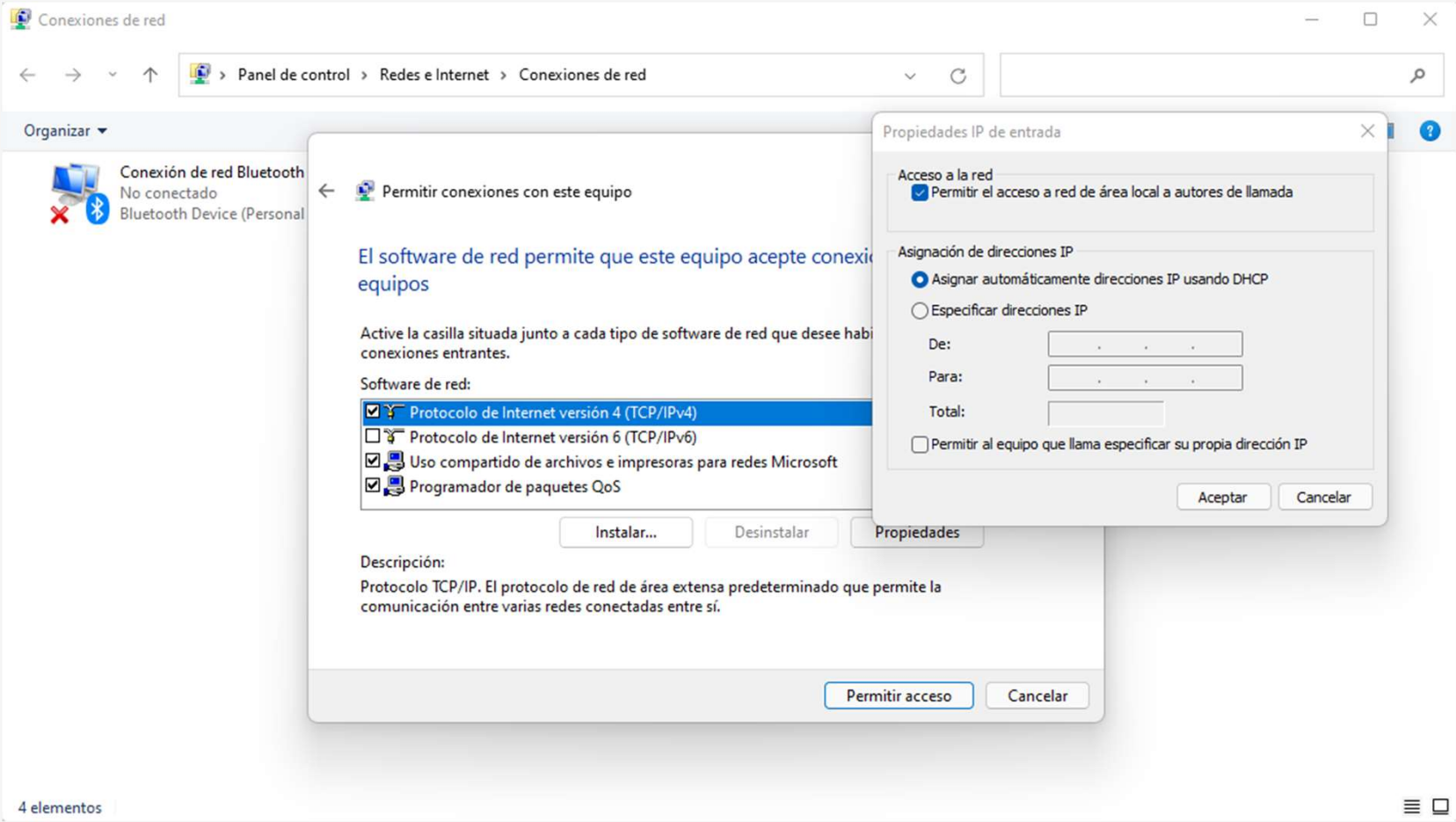
Configuración VPN W10



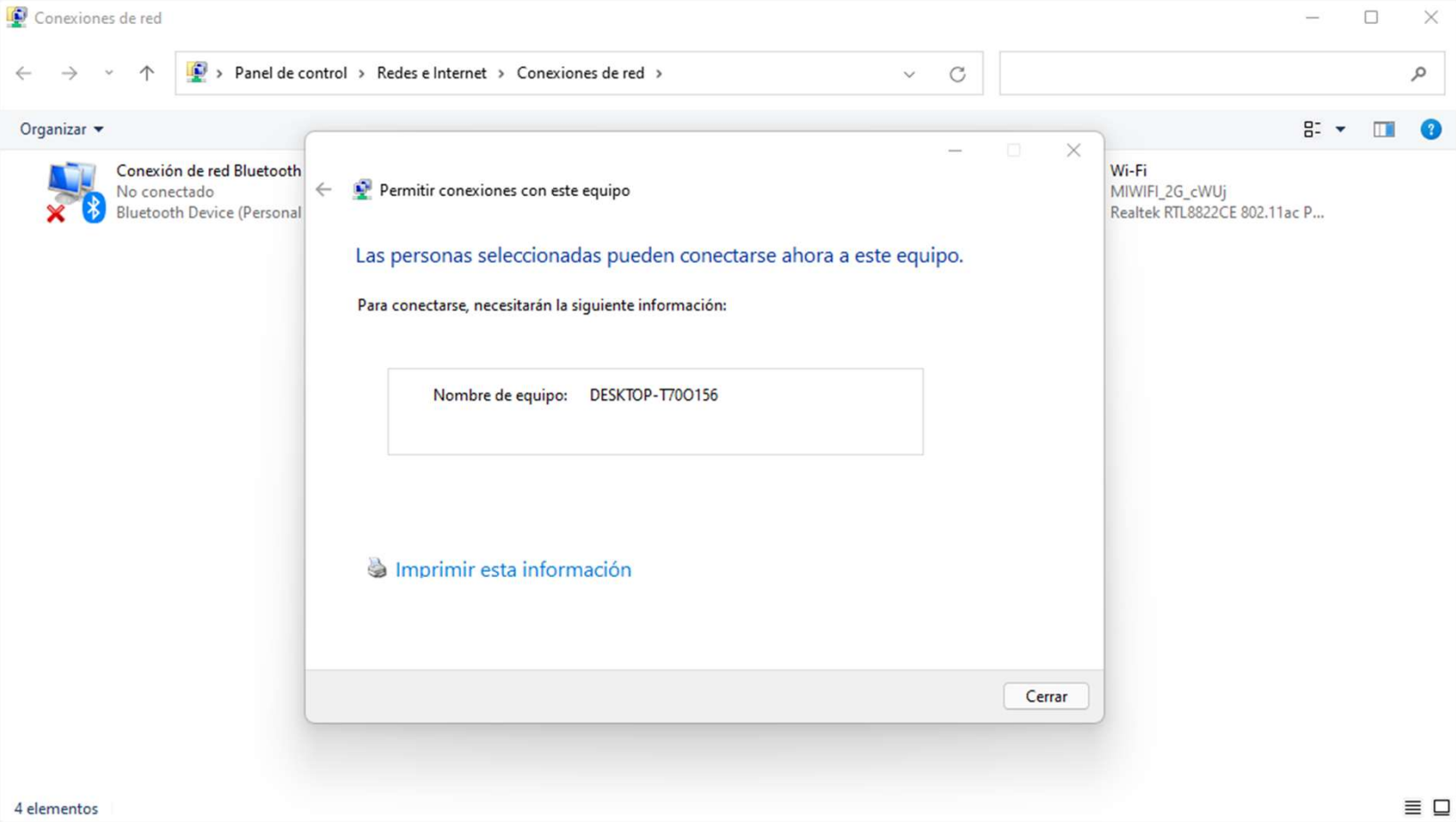
Configuración VPN W10



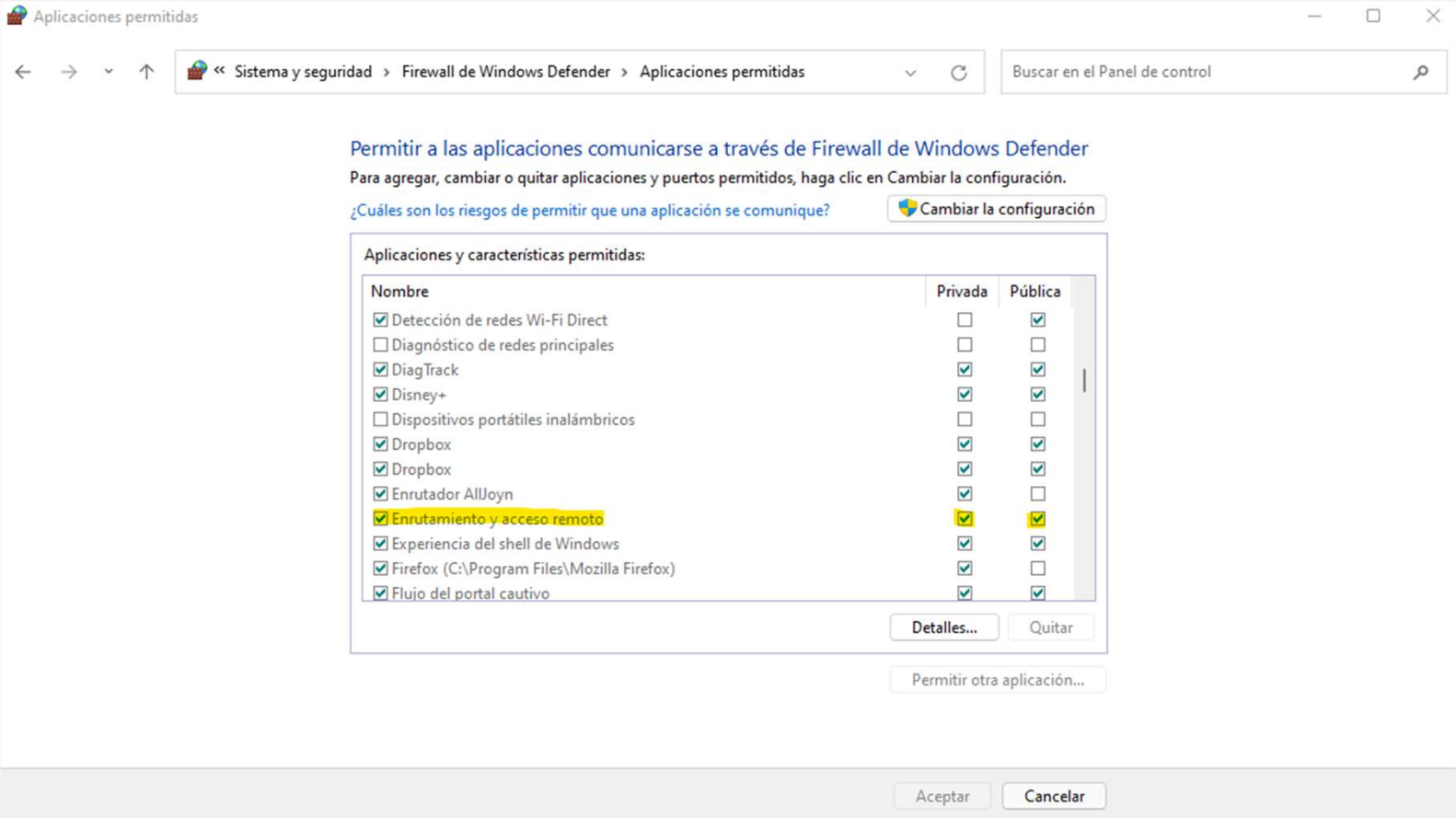
Configuración VPN W10



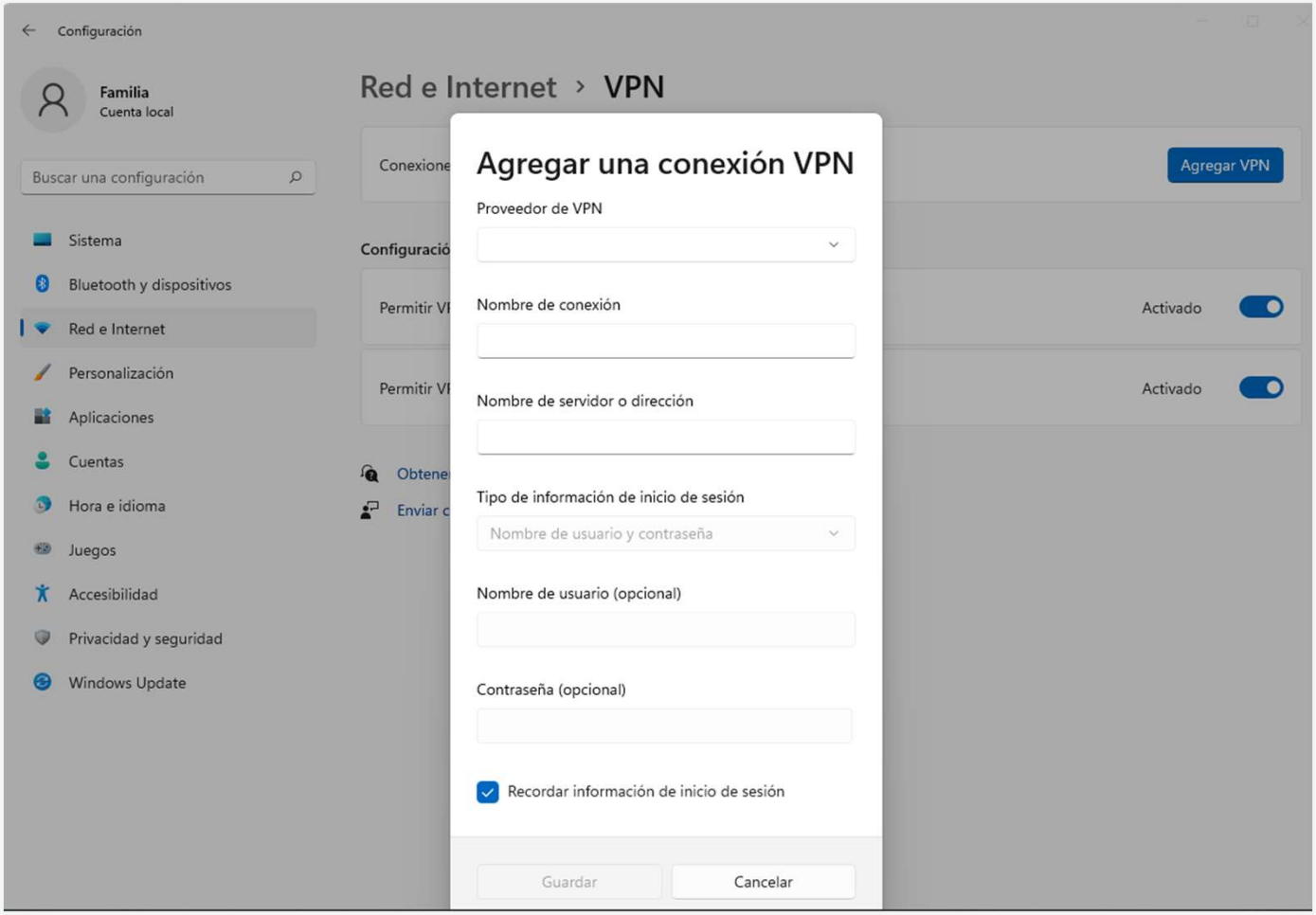
Configuración VPN W10



Configuración VPN W10 firewall



Conexión VPN cliente Win11



Ventajas de una VPN

- Dentro de las ventajas más significativas podremos mencionar la **integridad**, **confidencialidad** y **seguridad** de los datos.
- Reducción de costos.
- Sencillez de uso.
- Sencilla instalación del cliente en cualquier PC Windows.
- Control de Acceso basado en políticas de la organización
- Herramientas de diagnostico remoto.
- Los algoritmos de compresión optimizan el tráfico del cliente.